COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.2 · Common Threat Vectors

Mestre CyberSec · **Aula 2.2 — Common Threat Vectors** (17:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Vetores = como o ataque chega: email/SMS/voz, imagem, arquivo, chamada, credencial default nunca trocada, software infectado, USB baiting, malvertising (anúncio malicioso), credential stuffing (reuso de senha vazada), insider, rede remota, IoT/nuvem física.

💡 Highlights que a prova CompTIA cobra

- Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA
- Malvertising: anúncio malicioso em site legítimo
- Credential stuffing = USAR senha vazada em outros sites (vs brute force)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.2 — Common Threat Vectors)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Preenchimento de Credenciais (N/A)

Ataque em que credenciais vazadas (pares usuário/senha) em violações de dados anteriores são reutilizadas automaticamente em vários sites não relacionados para obter acesso não autorizado.

⚠ ***Armadilha CompTIA:*** *Trigger phrase 'reuses leaked credentials across multiple sites' = Credential Stuffing. Do NOT confuse with Brute Force (which guesses passwords without prior breach data) or Password Spraying (tries common passwords against many users).*

• Publicidade Maliciosa (N/A)

Código malicioso injetado em redes legítimas de publicidade online que redireciona usuários para kits de exploração ou instala malware quando o anúncio é exibido em sites confiáveis.

⚠ ***Armadilha CompTIA:*** *Trigger phrase 'malicious advertisement on a legitimate website' = Malvertising. Key distinction: the site itself is NOT compromised; only the ad content served through the ad network is malicious.*

• Isca USB (N/A)

Ataque de engenharia social física em que o invasor deixa unidades USB infectadas em locais públicos esperando que um usuário curioso as conecte em uma estação de trabalho, executando malware embutido.

⚠ ***Armadilha CompTIA:*** *Classified under the PHYSICAL threat vector category. Distinguish from supply chain attacks (USB shipped in hardware) — baiting relies on human curiosity and is intentionally placed.*

• Ataque à Cadeia de Suprimentos (N/A)

Ataque que compromete um fornecedor terceirizado confiável, atualização de software ou componente de hardware para distribuir malware aos usuários finais e organizações a jusante.

⚠ ***Armadilha CompTIA:*** *Look for hints like 'compromised software update', 'malicious code in legitimate hardware', or 'third-party vendor breach'. Differentiate from direct attacks — the victim trusts the source because it's the genuine vendor.*

• Credenciais Padrão (N/A)

Nomes de usuário e senhas definidos de fábrica (ex.: admin/admin) enviados inalterados em dispositivos como roteadores, dispositivos IoT e servidores, criando acesso não autorizado imediato se nunca forem modificados.

⚠️ ***Armadilha CompTIA:*** *On the exam, 'never changed the default password' or 'using factory credentials' = Default Credentials vulnerability. Common in IoT and network infrastructure devices.*

• Phishing (Email/SMS/Voz) (N/A)

Engenharia social entregue por e-mail (phishing), SMS (smishing) ou chamadas de voz (vishing) que engana usuários para revelar credenciais, clicar em links maliciosos ou baixar malware.

⚠️ ***Armadilha CompTIA:*** *Know the trio: Email = Phishing, SMS = Smishing, Voice = Vishing. All are message-based vectors. Whaling targets executives; Spear Phishing targets specific individuals using researched info.*

• Ameaça Interna (N/A)

Ameaça originada de pessoas dentro da organização — funcionários, contratados ou parceiros — que usam indevidamente o acesso legítimo para prejudicar sistemas, roubar dados ou vazar informações, intencionalmente ou acidentalmente.

⚠️ ***Armadilha CompTIA:*** *Trigger phrases: 'malicious employee', 'disgruntled staff', 'negligent contractor', or 'privileged user abuse'. Distinguish from external attackers — insider already has authorized network access.*

• Acesso Remoto Inseguro / Superfície de Ataque IoT (N/A)

Exploração de serviços remotos mal protegidos (RDP, SSH, VPN) e dispositivos IoT que não possuem hardening, patching ou segmentação de rede adequados, expondo-os a invasores externos.

⚠️ ***Armadilha CompTIA:*** *Exam will mention 'exposed RDP', 'unpatched IoT camera', or 'open SSH port to internet'. Remember: IoT devices often ship with default credentials AND unencrypted remote access enabled.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

O portal de webmail de uma empresa de serviços financeiros registra um aumento repentino de logins bem-sucedidos de diferentes endereços IP. Os nomes de usuário e senhas correspondem a credenciais de uma violação recente em um aplicativo de fitness popular. Muitos funcionários usaram a mesma senha para ambos os serviços. Qual vetor de ameaça é mais provável?

A) Password spraying

B) Credential stuffing

C) Ataque de força bruta

D) Sequestro de sessão

QUESTÃO 2 · CENÁRIO DE EXAME

Vários funcionários de um contratante de defesa encontram pen drives USB no estacionamento e na sala de descanso. Os drives estão rotulados como 'Demissões do 4º Trimestre' e 'Lista Confidencial de Bônus'. Um funcionário conecta um drive a uma estação de trabalho corporativa, e o malware é instalado silenciosamente. Qual vetor de ameaça é este?

A) Watering hole

B) Ataque à cadeia de suprimentos

C) USB baiting

D) Malvertising

QUESTÃO 3 · CENÁRIO DE EXAME

Usuários de uma empresa de marketing visitam um site de notícias legítimo. A rede de anúncios do site exibe um anúncio malicioso que redireciona alguns navegadores para um exploit kit. Nenhum usuário clicou no anúncio, mas uma tentativa de download drive-by tenta instalar malware. Qual vetor de ameaça está envolvido?

A) Malvertising

B) Typosquatting

C) Credential stuffing

D) Ameaça interna

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa instala uma atualização de rotina de um fornecedor de software confiável. A atualização é assinada digitalmente, mas contém um backdoor oculto que permite aos atacantes acessar dados de clientes. Qual vetor de ameaça é este?

A) USB baiting

B) Credenciais padrão

C) Vishing

D) Ataque à cadeia de suprimentos

QUESTÃO 5 · CENÁRIO DE EXAME

Uma avaliação de segurança descobre que muitos roteadores de rede e câmeras IP em um escritório corporativo ainda usam o nome de usuário e a senha de administrador padrão do fabricante. Atacantes obtêm acesso e alteram as configurações dos dispositivos. Qual vetor de ameaça é mais diretamente explorado?

A) Credenciais padrão

B) Credential stuffing

C) Exploit de dia zero

D) Malvertising

QUESTÃO 6 · CENÁRIO DE EXAME

Um funcionário do setor de contabilidade recebe um e-mail que parece ser do CFO. O e-mail pede que o funcionário abra um arquivo anexo de 'fatura urgente' e habilite macros para visualizá-lo. Depois disso, o malware é executado. Qual vetor de ameaça é este?

A) Smishing

B) Vishing

C) Phishing por e-mail com anexo malicioso

D) USB baiting

QUESTÃO 7 · CENÁRIO DE EXAME

Funcionários recebem mensagens de texto alegando que a senha da VPN corporativa expirará hoje. A mensagem inclui um link para uma página de login falsa que coleta credenciais. Qual vetor de ameaça é este?

A) Vishing

B) Smishing

C) Phishing por e-mail

D) Credential stuffing

QUESTÃO 8 · CENÁRIO DE EXAME

Um atacante liga para um funcionário e afirma ser do help desk de TI. O interlocutor diz que há um problema com a conta do funcionário e pede que ele leia a senha de uso único enviada para seu telefone. O atacante então a usa para fazer login. Qual vetor de ameaça é este?

A) Smishing

B) Phishing por e-mail

C) USB baiting

D) Vishing

QUESTÃO 9 · CENÁRIO DE EXAME

Um funcionário insatisfeito com acesso autorizado ao banco de dados de clientes copia milhares de registros para uma conta pessoal de armazenamento em nuvem pouco antes de pedir demissão. As credenciais do funcionário eram válidas e nenhum malware externo estava envolvido. Qual vetor de ameaça é este?

A) Ameaça interna

B) Ataque à cadeia de suprimentos

C) Malvertising

D) Acesso remoto não seguro

QUESTÃO 10 · CENÁRIO DE EXAME

Um hospital possui bombas de infusão conectadas à internet que executam firmware desatualizado e são acess��veis a partir da rede Wi-Fi de visitantes. Atacantes exploram as bombas para obter um ponto de apoio e se mover lateralmente. Qual vetor de ameaça é mais diretamente explorado?

A) Ataque à cadeia de suprimentos

B) Superfície de ataque de IoT

C) Credential stuffing

D) Vishing

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Credential stuffing

Os atacantes pegam pares de nome de usuário/senha vazados em uma violação e tentam usá-los em outros sites. Isso é credential stuffing. Password spraying usa poucas senhas comuns em muitas contas; força bruta adivinha senhas; sequestro de sessão rouba tokens de sessão ativos.

Questão 2: Alternativa C — USB baiting

Deixar pen drives infectados para as vítimas encontrarem e conectarem é USB baiting. Watering hole compromete um site frequentado pelos alvos; cadeia de suprimentos compromete um fornecedor; malvertising usa anúncios maliciosos.

Questão 3: Alternativa A — Malvertising

Malvertising é publicidade maliciosa entregue por meio de redes de anúncios legítimas. Typosquatting usa domínios parecidos; credential stuffing usa credenciais vazadas; ameaça interna é alguém de dentro da organização.

Questão 4: Alternativa D — Ataque à cadeia de suprimentos

Um ataque à cadeia de suprimentos compromete um fornecedor ou atualização de software confiável para entregar malware. USB baiting usa drives físicos; credenciais padrão são senhas não alteradas; vishing é phishing por voz.

Questão 5: Alternativa A — Credenciais padrão

Credenciais padrão são nomes de usuário/senhas definidos de fábrica que nunca foram alterados. Credential stuffing usa credenciais vazadas de outras violações; exploits de dia zero usam vulnerabilidades desconhecidas; malvertising usa anúncios maliciosos.

Questão 6: Alternativa C — Phishing por e-mail com anexo malicioso

O ataque chega por e-mail e usa um anexo malicioso, um tipo de phishing. Smishing é phishing por SMS; vishing é phishing por voz; USB baiting usa drives físicos.

Questão 7: Alternativa B — Smishing

Smishing é phishing realizado por mensagens de texto/SMS. Vishing usa chamadas de voz; phishing por e-mail usa e-mail; credential stuffing usa credenciais vazadas de outros sites.

Questão 8: Alternativa D — Vishing

Vishing é phishing por voz, normalmente uma ligação telefônica que manipula a vítima para revelar informações confidenciais ou realizar uma ação. Smishing usa mensagens de texto; phishing por e-mail usa e-mail; USB baiting usa drives físicos.

Questão 9: Alternativa A — Ameaça interna

Uma ameaça interna envolve um indivíduo confiável que faz uso indevido de acesso legítimo. Ataques à cadeia de suprimentos comprometem fornecedores; malvertising usa anúncios; acesso remoto não seguro envolve exposição externa.

Questão 10: Alternativa B — Superfície de ataque de IoT

A superfície de ataque de IoT consiste em dispositivos conectados à internet com segurança fraca, firmware desatualizado ou serviços expostos. Cadeia de suprimentos compromete fornecedores; credential stuffing usa credenciais vazadas; vishing é phishing por voz.